

Recent Malware Incidents

1) Fortra GoAnywhere MFT — CVE-2025-10035

What happened

In September 2025 a critical deserialization vulnerability (tracked as CVE-2025-10035) was disclosed in Fortra's GoAnywhere Managed File Transfer (MFT) product. Security researchers reported evidence of exploitation in the wild prior to public disclosure.

Attack method

- The flaw is a deserialization issue in the License Servlet which allows an unauthenticated actor to trigger remote code execution (RCE).
- Because GoAnywhere is a network-facing file-transfer platform used to move sensitive files, successful exploitation allowed attackers to execute commands and potentially deploy follow-on payloads or data exfiltration tools.

Mitigation / resolution

- Fortra published an advisory and patches; customers were instructed to apply the vendor patches immediately.
- Short-term mitigations included disconnecting affected instances from the public Internet, blocking access to the affected servlet, and reviewing logs.
- Organizations were advised to run forensic checks and rotate any exposed credentials.

2) Pandoc SSRF attacks targeting AWS IMDS — CVE-2025-51591

What happened

In September 2025 researchers observed in-the-wild exploitation attempts of a Pandoc vulnerability (CVE-2025-51591) being used to target AWS EC2 Instance Metadata Service (IMDS) to steal IAM credentials and pivot within cloud environments.

Attack method

- The vulnerability is a Server-Side Request Forgery (SSRF) in Pandoc's HTML handling that can be abused to make requests from the host to internal services.
- Attackers leveraged SSRF to query the IMDS endpoint on EC2 instances and retrieve temporary IAM credentials, enabling access to AWS resources.

Mitigation / resolution

- Patch or update Pandoc to the fixed version.
- Enforce IMDSv2 on EC2 instances, disable IMDSv1.
- Apply principle of least privilege to IAM roles, rotate any compromised credentials.
- Run document-processing utilities (like Pandoc) with minimal privileges and network egress restrictions.

3) LockBit Ransomware — Disruption (Operation Cronos, 2024) and subsequent developments**What happened**

LockBit has been one of the most prolific ransomware families. In February 2024, Operation Cronos disrupted the LockBit infrastructure, seizing servers, domains, and crypto-assets and leading to arrests. Despite this, 2025 saw reports of new LockBit variants.

Attack method

- LockBit operates as ransomware-as-a-service (RaaS). Affiliates gain access via phishing, RDP compromise, VPN vulnerabilities, or stolen credentials.
- Once inside, attackers steal data, disable backups, and deploy encryption to disrupt operations.

Mitigation / resolution

- Law enforcement seized infrastructure and assets, releasing decryption keys for some victims.
- Organizations are urged to maintain offline backups, implement MFA, patch systems, segment networks, and use endpoint protections.
- Continuous monitoring and threat hunting remain necessary due to new variants.